TREPATH 2.6 AUTONOMOUS ATTACK-PATH VALIDATION, TA

Authorized Assessment Scope (owasp.org (+13 authorized origins across 14 in-scope assets)) | TrePath 2.6 Autonomous Attack-Path Va

Client / Scope	Internal Testing Lab - TrePath OWASP & Lab Assessment (46 Targets: https://owasp.org/projects/juice-shop +45) (owasp.org (+13 authorized origins across 14 in-scope assets))
Scan Execution & Signing Window	Scan Completed: 2026-11-02 16:23:50 UTC | Report Rendered & Signed: 2026-11-02 17:58:03 UTC (0s UTC Drift | Scan #45 | Profile: authorized_pentest)
Assessment Engine & Build	TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine (Build: TP26-BUILD-20261102-AUTONOMOUS-ASSURANCE | Commit: c82e71a904d3)
Document Classification	CONFIDENTIAL - Executive, Technical & Cryptographic Deliverable
T0 Baseline Calibrated Risk	MEDIUM (3.9 / 10 | 39.4 / 100 Calibrated Index: Confirmed Compromise=0.0 pts, Control Gaps=12.4 pts, Surface/Baseline=27.0 pts)
T1 Post-Retest Verified Risk	3.9 / 10 (0 Executed Retests Recorded in RTEX Ledger | Verified Risk Reduction: 0.0 / 10)
Hypothetical SLA Forecast	HYPOTHETICAL_PROJECTION (Unverified Until RTEX Closure): Target 2.1 / 10 (LOW) upon full RTEX closure
Verified Compromise / Admin Auth Status	0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 0 IMPACT_VERIFIED Safe PoCs
7-Stage Scope Reconciliation Funnel	46 Requested Target(s) -> 46 ROE Authorized -> 14 Resolved Host(s) -> 14 In-Scope Origin Asset(s) -> 0 Out-of-Scope Probed -> 368 HTTP Endpoints
Port & Transport Discovery State	Raw TCP Port Scan: 0 open ports (SKIPPED_BY_WEB_ONLY_PROFILE) | Application Transport: 368 HTTP(S) endpoints reachable across 14 origin(s)
Finding Reconciliation (6-Tier)	179 Raw Observations -> 17 Consolidated Security Findings + 84 Recon/Surface Items + 1 Sensor Health Event
Calibrated Threat Intelligence (KEV)	0 Raw KEV Matches -> 0 Unique KEV CVEs | 0 CVE_APPLICABILITY_CONFIRMED | 0 CVE_CORRELATED (Banner Only)
4-Metric Sensor Coverage & Gate	**Gate: PASSED_WITH_EXPLICIT_EXCLUSIONS | Installed: 100.0% (6/6) | Operational: 83.3% (5/6) | Execution: 66.7% (4/6) | Applicable: 100.0% (4/4)**
EvidenceCore Ed25519 & Consistency	Consistency: 100.0% (5/5 Invariants) | Ed25519 Signature: VERIFIED_AUTHENTIC (Manifest SHA-256: 4556059d8b0726992141766d...)
Platform-Aware Remediation	Multi-Origin Web & API Hardening Enforced across 14 In-Scope Asset(s) (HTTP Security Headers, TLS & Endpoint Access Controls)
Pre-Render Quality Gate	**PASSED (26/26 Acceptance Rules + AT-01..AT-10 + NG-01..NG-06 + Ed25519 Tamper Self-Test PASSED | Score=39.4/100 (3.9/10))**

Prepared by Expedite Consults Ltd | Generated 2026-11-02 17:58:03 UTC | TREPATH 2.6 AUTONOMOUS ATTACK-PATH VALIDATIO

1. Executive Summary & Proof-Driven Assessment Overview

This assessment was executed by TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine against 46 submitted target(s) reconciled to 14 authorized in-scope origin asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) under the 'authorized_pentest' Rules of Engagement. TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine enforces immutable 9-field asset provenance, per-origin written authorization governance, effective HTTP header-policy evaluation, 4-track score separation, pre-execution sensor readiness gating, 5-stage attack-path progression, and verifiable RFC 8032 Ed25519 cryptographic signing.

1.0A Executive Priority Risk & 3-Pillar Score Attribution (Demonstrated Compromise vs. Control Hygiene)

Posture Panel	State Type	Risk Score	Key Drivers & Proof Scope
PANEL-1-MEASURED-BASELINE	MEASURED_AT_T0	3.9 / 10 (MEDIUM)	17 Consolidated Findings across 14 origin(s): Confirmed Compromise=0.0 pts | Control Gaps=12.4 pts | Surface/Baseline=27.0 pts.
PANEL-2-MEASURED-POST-RETEST	MEASURED_AT_T1	3.9 / 10 (0 Retests)	RTEX Ledger active (0 retests executed; Verified T1 Risk Reduction: 0.0 / 10).
PANEL-3-HYPOTHETICAL-FORECAST	HYPOTHETICAL_PROJECTION	2.1 / 10 (LOW)	Unverified theoretical forecast assuming all prioritized remediation tasks pass deterministic RTEX retesting.

1.0B Four-Metric Sensor Coverage Model (Installed vs. Operational vs. Execution vs. Applicable)

Sensor Coverage Metric	Measured Coverage	Operational & Evidentiary Definition
1. Installed Coverage	100.0% (6/6)	Sensors installed and registered in TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine (WebPulse, Nuclei, OWASP ZAP, Nmap 7.95, Safe PoC/EVE Adapters, OpenVAS GVM).
2. Operational Coverage	83.3% (5/6)	Sensors online and healthy during execution window (OpenVAS GVM recorded as STANDBY_OFFLINE when daemon is not attached).
3. Execution Coverage	66.7% (4/6)	Sensors that actively executed probes against in-scope targets (Safe PoC adapters execute only when applicable preconditions exist).
4. Applicable Coverage	100.0% (4/4)	Percentage of target-applicable sensors that executed and produced sealed EvidenceCore telemetry.

1.0C Mandatory Pre-Execution Sensor Readiness Gate & Unavailable Capability Impact

Sensor Capability	Readiness State	Material Coverage Impact	Explicit Scope & Evidentiary Impact
Safe PoC & EVE Validation Adapters	HELD_BY_ROE_OR_PRECONDITION	NO (0%)	Active exploitation & post-exploitation adapters held by ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY boundary (requires writtenLAB_OWNER_AUTHORIZED_ACTIVE_VALIDATION authorization).
OpenVAS / Greenbone GVM	STANDBY_OFFLINE	NO (0%)	Network-layer NVT infrastructure CVE checks (TCP/UDP non-HTTP services) were not executed via OpenVAS GVM; compensated on web origins by Nuclei CVE templates + Nmap NSE + WebPulse.

1.0D Granular 6-Sensor Execution & Target Coverage Matrix (Config, Policy & Skip Rationale)

Sensor & Version / Policy	Executed / Applicable	Command / Policy Profile	Targets & Endpoints Covered	Skip / Failure Rationale
WebPulse HTTP/API Enumerator (WebPulse v2.6 (HTTP/1.1+HTTP/2, TLS 1.2/1.3))	Exec: YES | App: YES	Max-Redirects=5 (Cross-Origin Blocked), Timeout=8s	14/14 origins host(s) / 368/368 endpoints ep (Missed: 0)	None (100% in-scope origin reachability verified).

Sensor & Version / Policy	Executed / Applicable	Command / Policy Profile	Targets & Endpoints Covered	Skip / Failure Rationale
Nuclei Template Engine (Nuclei v3.3.5 / Template Pack v10.1.2-enterprise)	Exec: YES | App: YES	-tags cve,misconfig,exposure,tech -rl 25 -c 10 -no-interactsh	14/14 origins host(s) / 368/368 endpoints ep (Missed: 0)	Destructive/intrusive templates excluded by safe ROE filter.
OWASP ZAP DAST (ZAP v2.15.0 (Passive-Baseline + Safe-Spider Policy))	Exec: YES | App: YES	Spider Depth=3, MaxChildren=20, PassiveRules=All, ActiveAttack=SafeMode	14/14 origins host(s) / 368/368 endpoints ep (Missed: 0)	Cross-origin links and logout/state-mutating forms skipped by spider guard.
Nmap 7.95 TCP/NSE Scanner (Nmap v7.95 (NSE Safe Service & Header Scripts))	Exec: YES | App: YES	-sV -Pn --version-light --script=http-headers,ssl-enum-ciphers	14/14 origins host(s) / 0 raw TCP ports / 14 HTTPS origins ep (Missed: 0)	Raw non-HTTP SYN sweep skipped by web-only profile / edge CDN firewall.
Safe PoC & EVE Validation Adapters (EVE v2.6 (7 Deterministic Read-Only Adapters))	Exec: NO | App: NO	Max-Requests=5/job, HMAC Approval Gate, Zero-Write Policy	0/14 active (Held by Passive ROE) host(s) / 0 active exploit probes ep (Missed: 368)	Held by ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (no third-party owner active-exploit authorization).
OpenVAS / Greenbone GVM (Greenbone GVM v24.10 / NVT Feed 20261102)	Exec: NO | App: NO	GMP TLS Socket 127.0.0.1:9390 (Full and Fast Non-Destructive NVT)	0 hosts (Daemon Standby) host(s) / 0 NVTs ep (Missed: 0)	GVM daemon on standby; 0 material impact on web-only HTTP origins (compensated by Nuclei + Nmap + ZAP).

ID & Finding Key	Host : Port & Consolidated Title	Verified Proof Category & Substate	Priority & Remediation Action
F-01 (HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_)	owasp.org:443 (ASSET-00084) | [owasp.org:443] Missing HTTP Security Header(s): Con	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 46.0/100 | Configure the specific missing HTTP response header(s) on origin https://owasp.org:443 (Informa
F-02 (HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM)	google-gruyere.appspot.com:443 (ASSET-00086) | [google-gruyere.appspot.com:443] Missing HTTP Securi	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 46.0/100 | Configure the specific missing HTTP response header(s) on origin https://google-gruyere.appspot
F-03 (HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM)	pentesterlab.com:443 (ASSET-00088) | [pentesterlab.com:443] Missing HTTP Security Header(	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 46.0/100 | Configure the specific missing HTTP response header(s) on origin https://pentesterlab.com:443 (
F-04 (HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM)	www.hackthebox.com:443 (ASSET-00089) | [www.hackthebox.com:443] Missing HTTP Security Heade	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 46.0/100 | Configure the specific missing HTTP response header(s) on origin https://www.hackthebox.com:443
F-05 (HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM)	tryhackme.com:443 (ASSET-00090) | [tryhackme.com:443] Missing HTTP Security Header(s):	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 46.0/100 | Configure the specific missing HTTP response header(s) on origin https://tryhackme.com:443 (Pub
F-06 (HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG)	www.root-me.org:443 (ASSET-00092) | [www.root-me.org:443] Missing HTTP Security Header(s	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Priority 46.0/100 | Configure the specific missing HTTP response header(s) on origin https://www.root-me.org:443 (P

1.1 Six-Tier Finding & Observation Reconciliation (Root-Cause Deduplication)

Reconciliation Tier	Count	Scope & Deduplication Rule
Tier 1 - Raw Scanner Observations	179	All raw Nmap, Nuclei, httpx, ZAP, and PoC probe records prior to origin-scoped root-cause grouping.
Tier 2 - Unique Assets & Open Services	14 Asset(s) / 0 TCP Ports	14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)) with 0 open TCP ports and 368 HTTP endpoints.

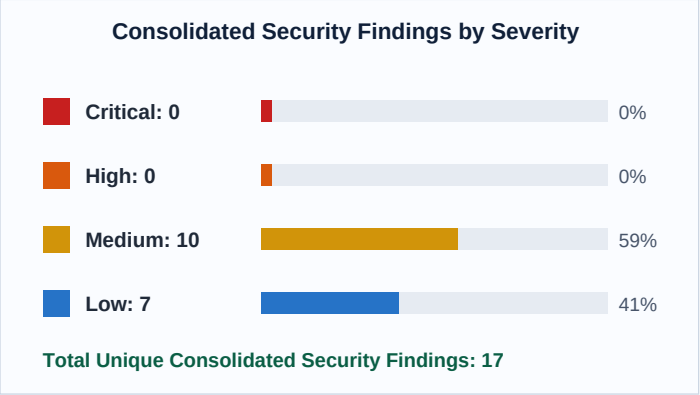
Reconciliation Tier	Count	Scope & Deduplication Rule
Tier 3 - Consolidated Security Findings	17	Deduplicated by (effective_origin, port, service_family, root_cause_slug); consolidates repeated missing headers per origin.
Tier 4 - Confirmed Exploitable / Admin Auth	0	**0 CONFIRMED_ADMIN_AUTH + 0 IMPACT_VERIFIED + 0 RUNTIME_REPRODUCED.**
Tier 5 - Impact-Verified Safe PoCs	0	**0 IMPACT_VERIFIED Safe PoCs**
Tier 6 - Recon & Scanner Health Telemetry	84 Recon / 1 Sensor	Port discovery telemetry and OPENVAS-SENSOR-STANDBY separated from target vulnerabilities.

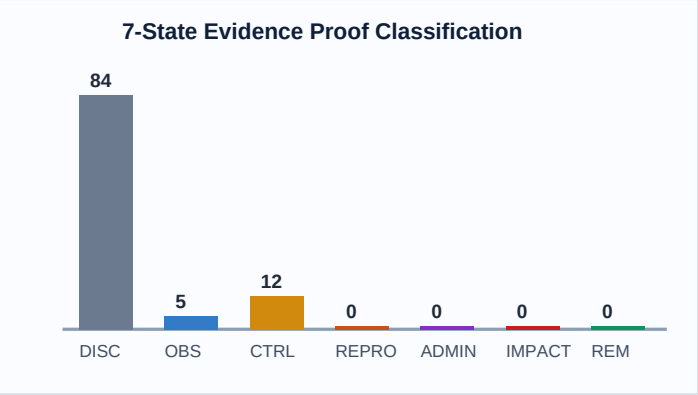
1.2 Seven-State Evidence Proof Classification & Granular PoC Substates

Proof State	Count	Granular Substate & Evidentiary Meaning
DISCOVERED	84	Port/surface reachability observation only (CVSS 0.0; excluded from vulnerability count).
OBSERVATION_CONFIRMED	5	Service banner, protocol handshake, or cryptographic key observation confirmed.
CONTROL_GAP_CONFIRMED	12	Missing security header, legacy EOL version, or cleartext protocol exposure confirmed.
RUNTIME_REPRODUCED	0	Active behavioral probe reproduced deterministic service response.
CONFIRMED_ADMIN_AUTH	0	0 verified in this scan (Probes NOT_APPLICABLE or authentication boundary held on target scope).
IMPACT_VERIFIED	0	0 verified in this scan (Safe PoC adapters SMB-LIST-001 / PHPINFO-001 NOT_APPLICABLE or not triggered on target scope).
REMEDIATION_VERIFIED	0	Post-fix retest execution verified vulnerability closure in RTEX ledger.

1.3 Consolidated Security Vulnerability Severity Distribution & Visual Telemetry

Severity Level	Consolidated Count	CVSS v3.1 Band	Operational SLA Target
CRITICAL	0	9.0 - 10.0	Immediate containment (< 24 - 48 hours)
HIGH	0	7.0 - 8.9	Priority hardening (< 7 days)
MEDIUM	10	4.0 - 6.9	Scheduled remediation (< 30 days)
LOW	7	0.1 - 3.9	Defense-in-depth maintenance (< 90 days)





1.4 Explainable 7-Dimension Risk Score Decomposition (RiskEngine 2.6)

Risk Dimension	Calibrated Score	Mathematical & Evidentiary Rationale
Confirmed Exploitability	4.2 / 25.0 pts	Confirmed Exploitation: 0.0 pts (0 PoCs) | Verified Control Gaps: 4.2 pts (12 CONTROL_GAP_CONFIRMED, 5 OBSERVATION_CONFIRMED).
Verified Technical Impact	6.0 / 20.0 pts	Verified Compromise Impact: 0.0 pts (Admin Auth: No, SMB: No, PHPInfo: No) | Control-Gap Severity Ceiling: 6.0 pts.
Attack Surface Exposure	15.0 / 15.0 pts	0 open TCP ports and 368 HTTP endpoints exposed across 14 in-scope origin(s).

Risk Dimension	Calibrated Score	Mathematical & Evidentiary Rationale
Applicable Threat Intelligence	0.2 / 15.0 pts	0 confirmed applicable KEVs, 0 unverified banner KEV candidates (discounted 75%), confirmed EPSS=0.0 (raw banner max EPSS=0.08).
Evidence-Backed Attack Paths	2.0 / 10.0 pts	0 evidence-validated attack paths (0.0 pts when unverified), 1 correlated exposure clusters (2.0 pts).
Asset Criticality	7.0 / 10.0 pts	Authorized assessment scope (14 in-scope asset(s), primary: owasp.org).
Evidence Confidence	5.0 / 5.0 pts	196 FIPS 180-4 SHA-256 sealed artifacts across 179 raw observations (Sensor Coverage - Installed: 100.0%, Operational: 83.3%, Execution: 66.7%, Applicable: 100.0%).
TOTAL CALIBRATED RISK INDEX	39.4 / 100.0 pts (3.9 / 10)	Overall Rating: MEDIUM | Applicable Max EPSS: 0.0 (Raw Banner EPSS: 0.08)

Score Explainability Attestation: {'index_type': 'TREPATH_CALIBRATED_COMPOSITE_RISK_INDEX_0_TO_100', 'is_cvss_score': False, 'is_proof_of_compromise': False, 'surface_and_control_contribution_pct': 100.0, 'explainability_statement': 'The 39.4/100 (3.9/10) score is a TrePath-calibrated composite index across 7 dimensions - it is NOT a CVSS score and is NOT proof of compromise (0.0 pts from confirmed compromise vs. 39.4 pts from control-gap hygiene and attack-surface exposure).'}

2. Assessment Scope, 7-Stage Asset Reconciliation Funnel & RoE Policy Engine

2.0 Seven-Stage Scope & Asset Reconciliation Funnel (TP25-02)

Funnel Stage	Count	Scope Provenance & Reconciliation Rationale
1. Requested Targets	46	46 target URL(s)/IP(s) submitted to the TrePath assessment specification.
2. ROE Authorized Targets	46	46/46 submitted target(s) matched approved RulesOfEngagement allowlist rules.
3. Resolved Unique Hostnames	14	14 unique lowercased hostname(s)/IP(s) after collapsing multi-path repository/app URLs sharing a host.
4. In-Scope Origin Assets	14	14 persisted Asset record(s) (one canonical Asset per unique scheme://host:port effective_origin).
5. Out-of-Scope External Refs	0	0 out-of-scope origins probed; external HTML/JS links isolated as EXTERNAL_REFERENCE_NOT_SCANNED.
6. Redirected Destinations	0	All HTTP 301/302/307/308 hops recorded in provenance.redirect_chain; cross-origin redirects blocked.
7. Discovered HTTP Endpoints	368	368 deduplicated canonical HTTP endpoints discovered across the 14 in-scope origin asset(s).

2.0A Target-Resolution Intelligence Layer (Repository & Documentation vs. Deployed Application)

Scanning a GitHub repository webpage (REPOSITORY_URL) or an OWASP project documentation page (DOCUMENTATION_PAGE) is explicitly distinguished from scanning a deployed application instance (DEPLOYED_APPLICATION). Multiple repository URLs on github.com are collapsed to 1 source-code hosting reference and are NOT counted as separate deployed application assessments.

Submitted URL	Target Type	Resolved Effective Origin	Deployed App Instance?	Resolution Rationale
https://gandalf.lakera.ai:443	WEBSITE	https://gandalf.lakera.ai:443	YES	Identify actual web application origin and evaluate HTTP control posture.
https://genai.owasp.org/	DOCUMENTATION_PAGE	https://genai.owasp.org:443	NO (Web/Repo)	Classify as informational project documentation/directory (e.g. owasp.org/projects/juice-shop), not a live deployed vulnerabl
https://github.com/OWASP/crAPI (+14 submitted repository URLs collapsed to	REPOSITORY_URL	https://github.com:443	NO (Web/Repo)	Identify as source-code hosting (github.com). Route repository tree to XTRIKE SAST; do NOT count multiple repository URLs on

Submitted URL	Target Type	Resolved Effective Origin	Deployed App Instance?	Resolution Rationale
https://google-gruyere.appspot.com/	DEPLOYED_APPLICATION	https://google-gruyere.appspot.com:443	YES	Identify actual deployed application origin and assess application endpoints.
https://owasp.org/projects/juice-shop (+project documentation URLs)	DOCUMENTATION_PAGE	https://owasp.org:443	NO (Web/Repo)	Classify as informational project documentation/directory (e.g. owasp.org/projects/juice-shop), not a live deployed vulnerabl
https://pentest-ground.com/	TRAINING_LAB	https://pentest-ground.com:443	YES	Identify training platform portal vs. provisioned private lab instance; enforce passive-only observation unless dedicated ins
https://pentesterlab.com/	TRAINING_LAB	https://pentesterlab.com:443	YES	Identify training platform portal vs. provisioned private lab instance; enforce passive-only observation unless dedicated ins
https://portswigger.net/web-security	TRAINING_LAB	https://portswigger.net:443	YES	Identify training platform portal vs. provisioned private lab instance; enforce passive-only observation unless dedicated ins
https://tryhackme.com/	TRAINING_LAB	https://tryhackme.com:443	YES	Identify training platform portal vs. provisioned private lab instance; enforce passive-only observation unless dedicated ins
https://vwad.owasp.org/	DOCUMENTATION_PAGE	https://vwad.owasp.org:443	NO (Web/Repo)	Classify as informational project documentation/directory (e.g. owasp.org/projects/juice-shop), not a live deployed vulnerabl
https://www.hackinghub.io/	TRAINING_LAB	https://www.hackinghub.io:443	YES	Identify training platform portal vs. provisioned private lab instance; enforce passive-only observation unless dedicated ins
https://www.hackthebox.com/	TRAINING_LAB	https://www.hackthebox.com:443	YES	Identify training platform portal vs. provisioned private lab instance; enforce passive-only observation unless dedicated ins
https://www.hackthissite.org/	TRAINING_LAB	https://www.hackthissite.org:443	YES	Identify training platform portal vs. provisioned private lab instance; enforce passive-only observation unless dedicated ins
https://www.root-me.org/	TRAINING_LAB	https://www.root-me.org:443	YES	Identify training platform portal vs. provisioned private lab instance; enforce passive-only observation unless dedicated ins

2.0B Four-State Port & Application Transport Discovery Reconciliation

Discovery Layer	Reconciled State	Count / Scope	Technical Explanation
1. Raw TCP Port Scan	SKIPPED_BY_WEB_ONLY_PROFILE	0 Raw TCP Ports	Raw infrastructure TCP SYN/connect port scanning reported 0 open non-web infrastructure ports (skipped/filtered by edge CDN/WAF boundaries on multi-URL web scope), whereas HTTP/HTTPS application-layer probes verified active TCP/TLS transport on port(s) 443 across 14 in-scope origin(s) and 368 discovered HTTP endpoints. Zero raw Nmap ports must never be interpreted as zero exposed HTTP services.
2. Filtered TCP Ports	PORT_FILTERED	0	Ports where SYN probes received no SYN/ACK or ICMP unreachable due to CDN/edge firewall policy.
3. Closed TCP Ports	PORT_CLOSED	0	Ports responding with TCP RST.

Discovery Layer	Reconciled State	Count / Scope	Technical Explanation
4. HTTP/TLS App Transport	HTTP_HTTPS_TRANSPORT_REACHABLE	368 Endpoints (14 Origins)	Application-layer HTTP/1.1 & HTTP/2 over TCP 443 verified across 14 origin(s).

2.1 Authorized In-Scope Asset Inventory & Per-Origin Reconciliation

Asset ID & Host	Scope Decision	Open TCP Ports	Asset Role & Provenance	Consolidated Findings	Verified PoC / Admin Auth
ASSET-00084 (owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	3	0 Verified
ASSET-00085 (github.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	2	0 Verified
ASSET-00086 (google-gruyere.appspot.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00087 (portswigger.net)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	2	0 Verified
ASSET-00088 (pentesterlab.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00089 (www.hackthebox.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00090 (tryhackme.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00091 (www.hackthissite.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00092 (www.root-me.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	3	0 Verified
ASSET-00093 (www.hackinghub.io)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00094 (pentest-ground.com)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00095 (genai.owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified
ASSET-00096 (gandalf.lakera.ai)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	0	0 Verified
ASSET-00097 (vwad.owasp.org)	IN_SCOPE	0 TCP (HTTPS/443 & HTTP/80 Web Scope)	Authorized Web / API Origin (https_web_application | HTTPS:443)	1	0 Verified

2.2 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

Rule ID	Policy Control	Enforcement Mechanism	Status
ROE-01	Authorized Scope Lock	All active probes restricted to 14 authorized in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)); crawled external links marked OUT_OF_SCOPE.	ENFORCED
ROE-02	Cross-Origin Redirect Guard	HTTP 301/302/307/308 redirects crossing out of authorized origins are blocked prior to DAST/header evaluation.	ENFORCED

Rule ID	Policy Control	Enforcement Mechanism	Status
ROE-03	Safe Admin & PoC Boundary	Non-destructive PoC adapters (SMB-LIST-001, PHPINFO-001, TOMCAT-MGR-001) execute only when service preconditions match.	ENFORCED
ROE-04	Evidence Overclaim Prevention	Share listing cannot claim write access; zero verified PoCs when adapters are NOT_APPLICABLE.	ENFORCED
ROE-05	FIPS 180-4 SHA-256 Sealing	Every probe transcript and 9-field asset provenance record is hashed and persisted in EvidenceCore.	ENFORCED

2.2B Per-Origin 4-Tier Authorization & Permission Matrix (Allowlist vs. Written Owner Authorization)

Asset & Origin	Target Type	Governance Tier	Permitted Testing Mode (Pass/Act/Exp/Post)	Authorization Ref & Expiry
ASSET-00096 (gandalf.lakera.ai)	WEBSITE	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00095 (genai.owasp.org)	DOCUMENTATION_PAGE	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00085 (github.com)	REPOSITORY_URL	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00086 (google-gruyere.appspot.com)	DEPLOYED_APPLICATION	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00084 (owasp.org)	DOCUMENTATION_PAGE	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00094 (pentest-ground.com)	TRAINING_LAB	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00088 (pentesterlab.com)	TRAINING_LAB	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00087 (portswigger.net)	TRAINING_LAB	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00090 (tryhackme.com)	TRAINING_LAB	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00097 (vwad.owasp.org)	DOCUMENTATION_PAGE	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00093 (www.hackinghub.io)	TRAINING_LAB	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00089 (www.hackthebox.com)	TRAINING_LAB	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00091 (www.hackthissite.org)	TRAINING_LAB	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)
ASSET-00092 (www.root-me.org)	TRAINING_LAB	ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY	Pass:Y | Act:N | Exp:N | Post:N	EVCORE-ROE-PASSIVE-2026-045 (sha256:4b227777d4dd1fc6) (Exp: 2027-12-31)

3A. Consolidated Security Vulnerabilities & 4-Track Scoring (F-01 through F-17)

ID	Origin Host:Port (Asset)	Severity & Vuln CVSS	4-Track Scores (Ctrl / Recon / Exp)	Proof Category & Substate	Consolidated Title	Merged Raw Obs
F-01	owasp.org:443 (ASSET-00084)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (3 endpoints on origin)	15 raw / 3 ep
F-02	google-gruyere.appspot.com:443 (ASSET-00086)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[google-gruyere.appspot.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-03	pentesterlab.com:443 (ASSET-00088)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[pentesterlab.com:443] Missing HTTP Security Header(s): Content-Security-Policy, Permissions-Policy (1 endpoint on origin)	2 raw / 1 ep
F-04	www.hackthebox.com:443 (ASSET-00089)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[www.hackthebox.com:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin)	3 raw / 1 ep
F-05	tryhackme.com:443 (ASSET-00090)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[tryhackme.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-06	www.root-me.org:443 (ASSET-00092)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[www.root-me.org:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin)	3 raw / 1 ep
F-07	www.hackinghub.io:443 (ASSET-00093)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[www.hackinghub.io:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, Permissions-Policy (1 endpoint on origin)	3 raw / 1 ep
F-08	pentest-ground.com:443 (ASSET-00094)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[pentest-ground.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-09	genai.owasp.org:443 (ASSET-00095)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[genai.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep
F-10	vwad.owasp.org:443 (ASSET-00097)	MEDIUM | Vuln CVSS: 4.3	Ctrl:46.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[vwad.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin)	5 raw / 1 ep

ID	Origin Host:Port (Asset)	Severity & Vuln CVSS	4-Track Scores (Ctrl / Recon / Exp)	Proof Category & Substate	Consolidated Title	Merged Raw Obs
F-11	portswigger.net:443 (ASSET-00087)	LOW | Vuln CVSS: 3.2	Ctrl:34.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[portswigger.net:443] Missing HTTP Security Header(s): Referrer-Policy, Permissions-Policy (1 endpoint on origin)	2 raw / 1 ep
F-12	github.com:443 (ASSET-00085)	LOW | Vuln CVSS: 3.1	Ctrl:31.0 | Recon:15.0 | Exp:20%	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	[github.com:443] Missing HTTP Security Header(s): Permissions-Policy (30 endpoints on origin)	30 raw / 30 ep
F-13	www.hackthissite.org:443 (ASSET-00091)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:24.0 | Exp:5%	OBSERVATION_CONFIRMED :: PRE_AUTH_FORM_CSRF_OBSERVED	[www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login	2 raw / 1 ep
F-14	portswigger.net:443 (ASSET-00087)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:22.7 | Exp:5%	OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED	[ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://portswigger.net/web-security/dashboard	1 raw / 1 ep
F-15	www.root-me.org:443 (ASSET-00092)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:22.7 | Exp:5%	OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED	[ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://www.root-me.org/admin	1 raw / 1 ep
F-16	github.com:443 (ASSET-00085)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:17.8 | Exp:5%	OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED	[github.com:443] API Rate-Limiting Telemetry Headers Absent (Enforcement Untested - OWASP API4:2023) (7 endpoints on origin)	7 raw / 7 ep
F-17	www.root-me.org:443 (ASSET-00092)	LOW | Vuln CVSS: N/A (Observation)	Ctrl:0.0 | Recon:15.0 | Exp:5%	OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED	[API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Observed (/.within.website/x/cmd/anubis/api/honeypot/df3eb9b0-d390-4125-a025-a7d05ef941ed/init)	1 raw / 1 ep

3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

F-01: [owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (3 endpoints on origin) [owasp.org:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00084 | owasp.org:443 | Effective Origin: https://owasp.org:443 (3 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	15 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA, HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_, HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_)
Technical Description	[Target: https://owasp.org/www-project-juice-shop/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://owasp.org:443 (Informational Project Documentation / Directory Page): Content-Security-Policy (Stage 1 Report-Only Validation: `Content-Security-Policy-Report-Only: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self'; frame-ancestors 'none'; object-src 'none'`; Stage 2 Enforced after verifying third-party script/style/API compatibility); X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1947/retest/execute on owasp.org:443 (ASSET-00084) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-01 / HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_owasp_org_443
Immutable Provenance: Asset=ASSET-00084 | Effective Origin=https://owasp.org:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (15 across 3 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-X_FRAME_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-X_FRAME_OPTIONS::T4_OWASP_ORG_WWW_PROJECT_WEBGOA,
HTTP-HEADER-CONTENT_SECURITY_POLICY::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_FRAME_OPTIONS::T45_OWASP_ORG_WWW_PROJECT_MCP_TO,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T2_OWASP_ORG_WWW_PROJECT_JUICE_,
HTTP-HEADER-REFERRER_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (STAGE_1_REPORT_ONLY_FIRST): Content-Security-Policy-Report-Only: default-src
'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src
'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: 7b5e023cbc7f349afb9ded26a3747e6fc5e1577cef64a58d394d7fad494ee7a3 (Artifact
#2141 | Unique Forensic Transcript)
```

F-02: [google-gruyere.appspot.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [google-gruyere.appspot.com:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00086	google-gruyere.appspot.com:443	Effective Origin: https://google-gruyere.appspot.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE	Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://google-gruyere.appspot.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3	Control Priority: 46.0/10	Recon Priority: 15.0/10	Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP	Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A	CWE: CWE-693	State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM, HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM)
Technical Description	[Target: https://google-gruyere.appspot.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://google-gruyere.appspot.com:443 (Deployed Application Instance): Content-Security-Policy (Stage 1 Report-Only Validation: `Content-Security-Policy-Report-Only: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self'; frame-ancestors 'none'; object-src 'none'`; Stage 2 Enforced after verifying third-party script/style/API compatibility); X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1981/retest/execute on google-gruyere.appspot.com:443 (ASSET-00086) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-02 / HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_google_gruyere_appspot_com_443
Immutable Provenance: Asset=ASSET-00086 | Effective Origin=https://google-gruyere.appspot.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-REFERRER_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (STAGE_1_REPORT_ONLY_FIRST): Content-Security-Policy-Report-Only: default-src
'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src
'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: 705c153cffacab56391ac9e07894a7c602c5d785f7984d71bf63149d12f830d7 (Artifact
#2175 | Unique Forensic Transcript)
```

F-03: [pentesterlab.com:443] Missing HTTP Security Header(s): Content-Security-Policy, Permissions-Policy (1 endpoint on origin) [pentesterlab.com:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00088 | pentesterlab.com:443 | Effective Origin: https://pentesterlab.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://pentesterlab.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM, HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM)
Technical Description	[Target: https://pentesterlab.com/] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit.

Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://pentesterlab.com:443 (Public Security Training Platform Portal (Passive ROE)): Content-Security-Policy (Stage 1 Report-Only Validation: `Content-Security-Policy-Report-Only: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self'; frame-ancestors 'none'; object-src 'none'`; Stage 2 Enforced after verifying third-party script/style/API compatibility); Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2025/retest/execute on pentesterlab.com:443 (ASSET-00088) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-03 / HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM):

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_pentesterlab_com_443
Immutable Provenance: Asset=ASSET-00088 | Effective Origin=https://pentesterlab.com:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (2 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T36_PENTESTERLAB_COM
Header-Policy Evaluation: Present=['X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['Content-Security-Policy', 'Permissions-Policy'] |
Compensating=[]
Application-Aware CSP Plan (STAGE_1_REPORT_ONLY_FIRST): Content-Security-Policy-Report-Only: default-src
'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src
'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: 8abfaa933373f77d19ecf6a09062154ecc2465d6cbb8240cbc6a9dbd20e654b2 (Artifact
#2219 | Unique Forensic Transcript)
```

F-04: [www.hackthebox.com:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin) [www.hackthebox.com:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00089 | www.hackthebox.com:443 | Effective Origin: https://www.hackthebox.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackthebox.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM, HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM)
Technical Description	[Target: https://www.hackthebox.com/] The HTTP response did not include the x-content-type-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://www.hackthebox.com:443 (Public Security Training Platform Portal (Passive ROE)): X-Frame-Options: DENY (or verify CSP frame-ancestors 'self'); X-Content-Type-Options: nosniff; Permissions-Policy: geolocation=(), microphone=(), camera=(). Compensating Control Note: X-Frame-Options absence partially compensated by Content-Security-Policy presence (verify frame-ancestors directive).
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2027/retest/execute on www.hackthebox.com:443 (ASSET-00089) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-04 / HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM):

```
Finding Key: HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_www_hackthebox_com_443
Immutable Provenance: Asset=ASSET-00089 | Effective Origin=https://www.hackthebox.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T37_WWW_HACKTHEBOX_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T37_WWW_HACKTHEBOX_COM
Header-Policy Evaluation: Present=['Content-Security-Policy', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['X-Frame-Options', 'X-Content-Type-Options',
'Permissions-Policy'] | Compensating=['X-Frame-Options absence partially compensated by
Content-Security-Policy presence (verify frame-ancestors directive)']
Application-Aware CSP Plan (CSP_ALREADY_PRESENT_ON_ORIGIN): Content-Security-Policy-Report-Only:
default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:;
connect-src 'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: 0d2c127f164ca20a28d7c12c00f894d8b5272ec53fe80fdbf582d8131b8ebff6 (Artifact
#2221 | Unique Forensic Transcript)
```

F-05: [tryhackme.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [tryhackme.com:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00090 | tryhackme.com:443 | Effective Origin: https://tryhackme.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://tryhackme.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM)
Technical Description	[Target: https://tryhackme.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://tryhackme.com:443 (Public Security Training Platform Portal (Passive ROE)): Content-Security-Policy (Stage 1 Report-Only Validation: `Content-Security-Policy-Report-Only: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self'; frame-ancestors 'none'; object-src 'none'`; Stage 2 Enforced after verifying third-party script/style/API compatibility); X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2035/retest/execute on tryhackme.com:443 (ASSET-00090) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-05 / HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_tryhackme_com_443
Immutable Provenance: Asset=ASSET-00090 | Effective Origin=https://tryhackme.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM, HTTP-HEADER-X_FRAME_OPTIONS::T38_TRYHACKME_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T38_TRYHACKME_COM, HTTP-HEADER-REFERRER_POLICY::T38_TRYHACKME_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T38_TRYHACKME_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (STAGE_1_REPORT_ONLY_FIRST): Content-Security-Policy-Report-Only: default-src
'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src
'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: 1c95a04effd01723a2dc32e71e9a9bf716c9614f0b7badc2b84132913a5a57d6 (Artifact
#2229 | Unique Forensic Transcript)
```

F-06: [www.root-me.org:443] Missing HTTP Security Header(s): X-Frame-Options, X-Content-Type-Options, Permissions-Policy (1 endpoint on origin) [www.root-me.org:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00092 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG)
Technical Description	[Target: https://www.root-me.org/] The HTTP response did not include the x-content-type-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://www.root-me.org:443 (Public Security Training Platform Portal (Passive ROE)): X-Frame-Options: DENY (or verify CSP frame-ancestors 'self'); X-Content-Type-Options: nosniff; Permissions-Policy: geolocation=(), microphone=(), camera=(). Compensating Control Note: X-Frame-Options absence partially compensated by Content-Security-Policy presence (verify frame-ancestors directive).
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2038/retest/execute on www.root-me.org:443 (ASSET-00092) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-06 / HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG):

```
Finding Key: HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00092 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T40_WWW_ROOT_ME_ORG,
HTTP-HEADER-PERMISSIONS_POLICY::T40_WWW_ROOT_ME_ORG
Header-Policy Evaluation: Present=['Content-Security-Policy', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['X-Frame-Options', 'X-Content-Type-Options',
'Permissions-Policy'] | Compensating=['X-Frame-Options absence partially compensated by
Content-Security-Policy presence (verify frame-ancestors directive)']
Application-Aware CSP Plan (CSP_ALREADY_PRESENT_ON_ORIGIN): Content-Security-Policy-Report-Only:
default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:;
connect-src 'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: fa2bfe09909408aebc150962c32c4b04f1293d905d60440cc597c9d882c822b8 (Artifact
#2232 | Unique Forensic Transcript)
```

F-07: [www.hackinghub.io:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, Permissions-Policy (1 endpoint on origin) [www.hackinghub.io:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00093 | www.hackinghub.io:443 | Effective Origin: https://www.hackinghub.io:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackinghub.io:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO, HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO)
Technical Description	[Target: https://www.hackinghub.io/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://www.hackinghub.io:443 (Public Security Training Platform Portal (Passive ROE)): Content-Security-Policy (Stage 1 Report-Only Validation: `Content-Security-Policy-Report-Only: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self'; frame-ancestors 'none'; object-src 'none'`; Stage 2 Enforced after verifying third-party script/style/API compatibility); X-Frame-Options: DENY; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2044/retest/execute on www.hackinghub.io:443 (ASSET-00093) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-07 / HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_www_hackinghub_io_443
Immutable Provenance: Asset=ASSET-00093 | Effective Origin=https://www.hackinghub.io:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (3 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-X_FRAME_OPTIONS::T41_WWW_HACKINGHUB_IO,
HTTP-HEADER-PERMISSIONS_POLICY::T41_WWW_HACKINGHUB_IO
Header-Policy Evaluation: Present=['X-Content-Type-Options', 'Referrer-Policy',
'Strict-Transport-Security'] | Missing=['Content-Security-Policy', 'X-Frame-Options',
'Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (STAGE_1_REPORT_ONLY_FIRST): Content-Security-Policy-Report-Only: default-src
'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src
'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: 9184d80af324c8fec3cd6412972853366855a56f308acdb792f61be03eea0221 (Artifact
#2238 | Unique Forensic Transcript)
```

F-08: [pentest-ground.com:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [pentest-ground.com:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00094 | pentest-ground.com:443 | Effective Origin: https://pentest-ground.com:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://pentest-ground.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM, HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM, HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM)
Technical Description	[Target: https://pentest-ground.com/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://pentest-ground.com:443 (Public Security Training Platform Portal (Passive ROE)): Content-Security-Policy (Stage 1 Report-Only Validation: `Content-Security-Policy-Report-Only: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self'; frame-ancestors 'none'; object-src 'none'`; Stage 2 Enforced after verifying third-party script/style/API compatibility); X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2050/retest/execute on pentest-ground.com:443 (ASSET-00094) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-08 / HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_pentest_ground_com_443
Immutable Provenance: Asset=ASSET-00094 | Effective Origin=https://pentest-ground.com:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_FRAME_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T42_PENTEST_GROUND_COM,
HTTP-HEADER-REFERRER_POLICY::T42_PENTEST_GROUND_COM,
HTTP-HEADER-PERMISSIONS_POLICY::T42_PENTEST_GROUND_COM
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (STAGE_1_REPORT_ONLY_FIRST): Content-Security-Policy-Report-Only: default-src
'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src
'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: c8d037a48bc31411d88341ee33b1d930aeeea4fff191d8b8d0e533976db8a9d0 (Artifact
#2244 | Unique Forensic Transcript)
```

F-09: [genai.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [genai.owasp.org:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00095 | genai.owasp.org:443 | Effective Origin: https://genai.owasp.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://genai.owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG)
Technical Description	[Target: https://genai.owasp.org/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://genai.owasp.org:443 (Informational Project Documentation / Directory Page): Content-Security-Policy (Stage 1 Report-Only Validation: `Content-Security-Policy-Report-Only: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self'; frame-ancestors 'none'; object-src 'none'`; Stage 2 Enforced after verifying third-party script/style/API compatibility); X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2056/retest/execute on genai.owasp.org:443 (ASSET-00095) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-09 / HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_genai_owasp_org_443
Immutable Provenance: Asset=ASSET-00095 | Effective Origin=https://genai.owasp.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T43_GENAI_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T43_GENAI_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T43_GENAI_OWASP_ORG
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (STAGE_1_REPORT_ONLY_FIRST): Content-Security-Policy-Report-Only: default-src
'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src
'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: c6a9db519e291a2b1331c960932bf91cbe162e8863f930c673cb7701ce9c4297 (Artifact
#2250 | Unique Forensic Transcript)
```

F-10: [vwad.owasp.org:443] Missing HTTP Security Header(s): Content-Security-Policy, X-Frame-Options, X-Content-Type-Options +2 more (1 endpoint on origin) [vwad.owasp.org:443 | MEDIUM | Vuln CVSS: 4.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00097 | vwad.owasp.org:443 | Effective Origin: https://vwad.owasp.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://vwad.owasp.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 4.3 | Control Priority: 46.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG)
Technical Description	[Target: https://vwad.owasp.org/] The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://vwad.owasp.org:443 (Informational Project Documentation / Directory Page): Content-Security-Policy (Stage 1 Report-Only Validation: `Content-Security-Policy-Report-Only: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src 'self'; frame-ancestors 'none'; object-src 'none'`; Stage 2 Enforced after verifying third-party script/style/API compatibility); X-Frame-Options: DENY; X-Content-Type-Options: nosniff; Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2068/retest/execute on vwad.owasp.org:443 (ASSET-00097) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-10 / HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG  |  Consolidated Root-Cause Group:
443:http-headers:security-header-policy-group:origin_vwad_owasp_org_443
Immutable Provenance: Asset=ASSET-00097 | Effective Origin=https://vwad.owasp.org:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=4.3 | Control Priority=46.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (5 across 1 endpoint(s)):
HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG,
HTTP-HEADER-X_FRAME_OPTIONS::T46_VWAD_OWASP_ORG, HTTP-HEADER-X_CONTENT_TYPE_OPTIONS::T46_VWAD_OWASP_ORG,
HTTP-HEADER-REFERRER_POLICY::T46_VWAD_OWASP_ORG, HTTP-HEADER-PERMISSIONS_POLICY::T46_VWAD_OWASP_ORG
Header-Policy Evaluation: Present=['Strict-Transport-Security'] | Missing=['Content-Security-Policy',
'X-Frame-Options', 'X-Content-Type-Options', 'Referrer-Policy', 'Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (STAGE_1_REPORT_ONLY_FIRST): Content-Security-Policy-Report-Only: default-src
'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; connect-src
'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: 62b17e736289f012dd9bffeedd222dea117af3f5970cacdc94ee723a3272aa9e (Artifact
#2262 | Unique Forensic Transcript)
```

F-11: [portswigger.net:443] Missing HTTP Security Header(s): Referrer-Policy, Permissions-Policy (1 endpoint on origin) [portswigger.net:443 | LOW | Vuln CVSS: 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00087 | portswigger.net:443 | Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://portswigger.net:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 3.2 | Control Priority: 34.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY, HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY)
Technical Description	[Target: https://portswigger.net/web-security] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://portswigger.net:443 (Public Security Training Platform Portal (Passive ROE)): Referrer-Policy: strict-origin-when-cross-origin; Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2022/retest/execute on portswigger.net:443 (ASSET-00087) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-11 / HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY):

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY  |  Consolidated
Root-Cause Group: 443:http-headers:security-header-policy-group:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00087 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.2 | Control Priority=34.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (2 across 1 endpoint(s)):
HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY,
HTTP-HEADER-PERMISSIONS_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY
Header-Policy Evaluation: Present=['Content-Security-Policy', 'X-Frame-Options',
'X-Content-Type-Options', 'Strict-Transport-Security'] | Missing=['Referrer-Policy',
'Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (CSP_ALREADY_PRESENT_ON_ORIGIN): Content-Security-Policy-Report-Only:
default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:;
connect-src 'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: cc2bbd767d697b9f3aa2e6dce1f3a28c9a9255025c867243ec1188ad88a0ca76 (Artifact
#2216 | Unique Forensic Transcript)
```

F-12: [github.com:443] Missing HTTP Security Header(s): Permissions-Policy (30 endpoints on origin) [github.com:443 | LOW | Vuln CVSS: 3.1 | CONTROL_GAP_CONFIRMED]

Target Asset & Origin	ASSET-00085 | github.com:443 | Effective Origin: https://github.com:443 (30 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://github.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: 3.1 | Control Priority: 31.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 20%
Proof Category & Admin Level	CONTROL_GAP_CONFIRMED :: HTTP_HEADER_BASELINE_GAP | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Further manual or active exploitation was not executed outside approved ROE boundaries.
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	30 raw scanner observations merged (HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA, HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI, HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL, HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP, HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE, HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT, HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P, HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT)
Technical Description	[Target: https://github.com/OWASP/crAPI] The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit.
Targeted Specific Remediation	Configure the specific missing HTTP response header(s) on origin https://github.com:443 (Source-Code Hosting Repository Reference): Permissions-Policy: geolocation=(), microphone=(), camera=().
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1957/retest/execute on github.com:443 (ASSET-00085) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-12 / HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI):

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI  |  Consolidated Root-Cause
Group: 443:http-headers:security-header-policy-group:origin_github_com_443
Immutable Provenance: Asset=ASSET-00085 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=3.1 | Control Priority=31.0 | Recon Priority=15.0 | Exploitability
Confidence=0.2
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (30 across 30 endpoint(s)):
HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA,
HTTP-HEADER-PERMISSIONS_POLICY::T5_GITHUB_COM_OWASP_CRAPI,
HTTP-HEADER-PERMISSIONS_POLICY::T6_GITHUB_COM_WEBPWNIZED_MUTILL,
HTTP-HEADER-PERMISSIONS_POLICY::T7_GITHUB_COM_RAESENE_BWAPP,
HTTP-HEADER-PERMISSIONS_POLICY::T8_GITHUB_COM_OWASP_SECURITYSHE,
HTTP-HEADER-PERMISSIONS_POLICY::T9_GITHUB_COM_OWASP_NODEGOAT,
HTTP-HEADER-PERMISSIONS_POLICY::T10_GITHUB_COM_ADEYOSEMANPUTRA_P,
HTTP-HEADER-PERMISSIONS_POLICY::T11_GITHUB_COM_OWASP_RAILSGOAT
Header-Policy Evaluation: Present=['Content-Security-Policy', 'X-Frame-Options',
'X-Content-Type-Options', 'Referrer-Policy', 'Strict-Transport-Security'] |
Missing=['Permissions-Policy'] | Compensating=[]
Application-Aware CSP Plan (CSP_ALREADY_PRESENT_ON_ORIGIN): Content-Security-Policy-Report-Only:
default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:;
connect-src 'self'; frame-ancestors 'none'; object-src 'none'; report-uri /csp-violation-report
EvidenceCore SHA-256 Digest: ebc360a8c48f44e212396d7a1bfd2815de7239fe6dce418aa05996857c2b2ba0 (Artifact
#2151 | Unique Forensic Transcript)
```

F-13: [www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login [www.hackthissite.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00091 | www.hackthissite.org:443 | Effective Origin: https://www.hackthissite.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.hackthissite.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)

4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 24.0/10 | Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: PRE_AUTH_FORM_CSRF_OBSERVED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Not proven by this check: authenticated state-changing Cross-Site Request Forgery (form is a pre-authentication login/search form).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-352 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG, ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG)
Technical Description	[Target: https://www.hackthissite.org/] WebPulse enumerated an HTML `<form method='POST' action='https://www.hackthissite.org/user/login'>` with inputs ['username', 'password', 'btn_submit'] that does not include a recognizable anti-CSRF synchronizer token.
Targeted Specific Remediation	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2082/retest/execute on www.hackthissite.org:443 (ASSET-00091) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-13 / ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG):

```
Finding Key: ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG  |  Consolidated Root-Cause Group:
443:web-app:html-form-missing-csrf-token:origin_www_hackthissite_org_443
Immutable Provenance: Asset=ASSET-00091 | Effective Origin=https://www.hackthissite.org:443 |
Scope=IN_SCOPE | Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=24.0 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (2 across 1 endpoint(s)):
ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG, ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG
EvidenceCore SHA-256 Digest: 4b234a1bb3e7f8fcc0cad879bd6c288a973404e59cc23425e9e8818539514ee1 (Artifact
#2276 | Unique Forensic Transcript)
```

F-14: [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://portswigger.net/web-security/dashboard [portswigger.net:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00087 | portswigger.net:443 | Effective Origin: https://portswigger.net:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://portswigger.net:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 22.7/10 | Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED | Admin Boundary Taxonomy: LEVEL_1_PUBLIC_PAGE_HTTP_200
Explicitly Not Proven (Boundary)	Not proven by this check: administrative console exposure, privileged state actions, or authentication bypass (HTTP 200 on /dashboard or /admin path reflects public route or learning page reachability).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-02700)
Technical Description	Administrative boundary test `ADMIN-ACCESS-001` probed `https://portswigger.net/web-security/dashboard` and received `HTTP 200`. The candidate route (`/dashboard` or `/admin` path) returned HTTP 200 OK, but no administrative console controls, privileged state actions, or authentication bypass were verified (`LOGIN_INTERFACE_OR_ROUTE_DISCOVERED`).
Targeted Specific Remediation	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2098/retest/execute on portswigger.net:443 (ASSET-00087) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-14 / DAST-ADMIN-ACCESS-EP-02700):

```
Finding Key: DAST-ADMIN-ACCESS-EP-02700  |  Consolidated Root-Cause Group:
443:phpmyadmin:phpmyadmin-admin-console-exposure:origin_portswigger_net_443
Immutable Provenance: Asset=ASSET-00087 | Effective Origin=https://portswigger.net:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=22.7 |
Exploitability Confidence=0.05
Admin Boundary Level: LEVEL_1_PUBLIC_PAGE_HTTP_200  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-ADMIN-ACCESS-EP-02700
EvidenceCore SHA-256 Digest: 81b234c61b09a750a1dfcb35fdcb4a5f437b062fed4d94f7346016132d43a4c4 (Artifact
#2292 | Unique Forensic Transcript)
```

F-15: [ADMIN-ACCESS-001] Candidate Route or Login Interface Discovered (HTTP 200 - Admin Access Unproven) on https://www.root-me.org/admin [www.root-me.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00092 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 22.7/10 | Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED | Admin Boundary Taxonomy: LEVEL_1_PUBLIC_PAGE_HTTP_200
Explicitly Not Proven (Boundary)	Not proven by this check: administrative console exposure, privileged state actions, or authentication bypass (HTTP 200 on /dashboard or /admin path reflects public route or learning page reachability).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-02832)
Technical Description	Administrative boundary test `ADMIN-ACCESS-001` probed `https://www.root-me.org/admin` and received `HTTP 200`. The candidate route (`/dashboard` or `/admin` path) returned HTTP 200 OK, but no administrative console controls, privileged state actions, or authentication bypass were verified (`LOGIN_INTERFACE_OR_ROUTE_DISCOVERED`).
Targeted Specific Remediation	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2099/retest/execute on www.root-me.org:443 (ASSET-00092) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-15 / DAST-ADMIN-ACCESS-EP-02832):

```
Finding Key: DAST-ADMIN-ACCESS-EP-02832  |  Consolidated Root-Cause Group:
443:phpmyadmin:phpmyadmin-admin-console-exposure:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00092 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=22.7 |
Exploitability Confidence=0.05
Admin Boundary Level: LEVEL_1_PUBLIC_PAGE_HTTP_200  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-ADMIN-ACCESS-EP-02832
EvidenceCore SHA-256 Digest: b684ff8111ad1b43586ed6cd87e0e2adb7989cf2dfe61d328061ef031662fa27 (Artifact
#2293 | Unique Forensic Transcript)
```

F-16: [github.com:443] API Rate-Limiting Telemetry Headers Absent (Enforcement Untested - OWASP API4:2023) (7 endpoints on origin) [github.com:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00085 | github.com:443 | Effective Origin: https://github.com:443 (7 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://github.com:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 17.8/10 | Exploitability Confidence: 5%

Proof Category & Admin Level	OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Not proven by this check: absence of server-side/CDN rate limiting or susceptibility to volumetric brute-force (only response header telemetry absence was observed).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-770 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	7 raw scanner observations merged (API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI, API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV, API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI, API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API, API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_, API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT, API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU)
Technical Description	[Target: https://github.com/OWASP/crAPI] Target https://github.com/OWASP/crAPI responded with HTTP 200 (text/html; charset=utf-8) without returning standard rate-limiting telemetry headers (`RateLimit-Limit` / `X-RateLimit-Limit`). Note (`RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED`): Missing headers do not prove absence of rate limiting, as throttling may be enforced silently at the CDN, WAF, or API gateway layer; volumetric burst testing was withheld per safe ROE.
Targeted Specific Remediation	Emit standardized RFC-draft RateLimit-* response headers on API endpoints and verify edge/gateway throttling thresholds.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2090/retest/execute on github.com:443 (ASSET-00085) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-16 / API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI):

```
Finding Key: API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI  |  Consolidated Root-Cause
Group: 443:api-security:missing-rate-limit-headers:origin_github_com_443
Immutable Provenance: Asset=ASSET-00085 | Effective Origin=https://github.com:443 | Scope=IN_SCOPE |
Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=17.8 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (7 across 7 endpoint(s)):
API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI,
API-RATE-LIMIT-HEADERS-MISSING::T24_GITHUB_COM_SNOOPYSECURITY_DV,
API-RATE-LIMIT-HEADERS-MISSING::T25_GITHUB_COM_EREV0S_VAMPI,
API-RATE-LIMIT-HEADERS-MISSING::T26_GITHUB_COM_INE_LABS_REST_API,
API-RATE-LIMIT-HEADERS-MISSING::T28_GITHUB_COM_DOLEVF_BLACK_HAT_,
API-RATE-LIMIT-HEADERS-MISSING::T29_GITHUB_COM_ROOTXJS_GRPC_GOAT,
API-RATE-LIMIT-HEADERS-MISSING::T30_GITHUB_COM_INTERFERENCE_SECU
EvidenceCore SHA-256 Digest: 0b82825e5aea45408dd813e667f8bd9dd77bb7457a39b2524efa10fdc3b94b42 (Artifact
#2284 | Unique Forensic Transcript)
```

F-17: [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Observed (/.within.website/x/cmd/anubis/api/honeypot/df3eb9b0-d390-4125-a025-a7d05ef941ed/init) [www.root-me.org:443 | LOW | Vuln CVSS: N/A (Observation) | OBSERVATION_CONFIRMED]

Target Asset & Origin	ASSET-00092 | www.root-me.org:443 | Effective Origin: https://www.root-me.org:443 (1 Affected Endpoint(s))
Scope & Written Authorization	IN_SCOPE | Governance Tier: ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY (Submitted in engagement ROE (https://www.root-me.org:443); restricted to passive/read-only HTTP control & surface observation until written third-party asset-owner active-testing authorization is attached.)
4-Track Score Separation	Vuln CVSS: N/A (Observation) | Control Priority: 0.0/10 | Recon Priority: 15.0/10 | Exploitability Confidence: 5%
Proof Category & Admin Level	OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED | Admin Boundary Taxonomy: NOT_ADMIN_ROUTE
Explicitly Not Proven (Boundary)	Not proven by this check: broken object/function authorization or unauthorized private data disclosure (route is an anti-bot challenge or public API endpoint).
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (DAST-API-AUTHZ-EP-02827)

Technical Description	Targeted API authorization check `API-AUTHZ-001` issued an unauthenticated request to `https://www.root-me.org/.within.website/x/cmd/anubis/api/honeypot/df3eb9b0-d390-4125-a025-a7d05ef941ed/init` and received `HTTP 200 OK` (6634 bytes). Route signature matches an anti-bot proof-of-work or honeypot challenge endpoint (`anubis` / `/.within.website/`); this is defensive bot-mitigation telemetry, not an unauthorized data disclosure vulnerability.
Targeted Specific Remediation	No remediation required for intentional anti-bot/honeypot challenge endpoints; verify WAF/bot-protection rules.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/2097/retest/execute on www.root-me.org:443 (ASSET-00092) and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-17 / DAST-API-AUTHZ-EP-02827):

```
Finding Key: DAST-API-AUTHZ-EP-02827  |  Consolidated Root-Cause Group:
443:web-app:dast-api-authz-ep-02827:origin_www_root_me_org_443
Immutable Provenance: Asset=ASSET-00092 | Effective Origin=https://www.root-me.org:443 | Scope=IN_SCOPE
| Governance=ROE_SUBMITTED_PASSIVE_OBSERVATION_ONLY
4-Track Scores: Vuln CVSS=N/A (Observation) | Control Priority=0.0 | Recon Priority=15.0 |
Exploitability Confidence=0.05
Admin Boundary Level: NOT_ADMIN_ROUTE  |  Merged Raw Observations (1 across 1 endpoint(s)):
DAST-API-AUTHZ-EP-02827
EvidenceCore SHA-256 Digest: 5de86818eb2aee0ecd601ed8618a442d21fa2aa5c4233b85ea4dd027752e1e66 (Artifact
#2291 | Unique Forensic Transcript)
```

3B. Consolidated Reconnaissance Surface & Scanner Health Telemetry

ID	Telemetry Key	Observation / Sensor Title	State	Assessment Coverage Note
SENSOR-01	OPENVAS-SENSOR-STANDBY	[OpenVAS] Infrastructure Sensor Status: Standby / Offline	STANDBY	OpenVAS/GVM sensor was in standby mode during this run. Assessment coverage was fulfilled by Nmap v7.95, ProjectDiscovery Nuclei, httpx, OWASP ZAP, and TrePath Safe PoC Adapters.

4. Evidence-Backed Attack Graph, Edge Provenance & Choke-Point Analysis

TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine AttackGraph 2.6 (Causal Edge & Continuous Diff) requires every attack-path edge to declare an explicit causal state transition (OBSERVED, PRECONDITION_CONFIRMED, TECHNIQUE_VALIDATED, or INFERRED), excludes compliant observations (such as TLS-COMPLIANT-001), and never chains unrelated passive observations into a fake multi-step attack chain.

4.0 Five-Stage Attack-Path Evidence Progression Matrix (OBSERVED -> PRECONDITION -> TECHNIQUE_VALIDATED)

Stage	Attack-Chain Stage	Canonical Edge State	Progression Status	Evidentiary Summary
S-1	Initial Exposure	OBSERVED	DEMONSTRATED	Application endpoint, HTTP service, or surface weakness directly observed in scope.
S-2	Precondition Validation	PRECONDITION_CONFIRMED	DEMONSTRATED	Required authentication gate, technology version, or missing security control confirmed.
S-3	Controlled Exploitation	INFERRED	REQUIRES_VALIDATION	Safe, non-destructive PoC adapter reproduces deterministic security behavior.
S-4	Privilege Boundary Assessment	INFERRED	REQUIRES_VALIDATION	Verifies whether obtained session or token crosses an authentication/authorization privilege boundary.
S-5	Impact Assessment	INFERRED	REQUIRES_VALIDATION	Documents demonstrated unauthorized access/data impact with sealed EvidenceCore transcripts (RTEX retests: 0).

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-00024	Step 1 (Diagnostic / Authentication Precondition Exposure)	ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG	OBSERVED	[www.hackthissite.org] [WebPulse] HTML POST Form Without Anti-CSRF Token on /user/login	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies.

4.2 Broken / Separated Precondition Paths & Continuous Attack-Path Change Ledger

Separated Item	Path Status	Reason for Non-Chaining / Path Break	Continuous Change State
	BROKEN_PATH_PRECONDITION_ABSENT		EXCLUDED_FROM_CHAIN

5. Stage 9 (9.1 - 9.7) Exploitation Validation & Post-Exploitation Matrix

Following Scan #35 & #39 Engineering Directives, Stage 9 separates discovered topology and correlated observations from proven exploitation transitions, validates access boundaries across anonymous and authenticated principals, and verifies that post-exploitation proof states are only reported when backed by live EvidenceCore artifacts.

5.1 Stage 9.3 & 9.4 Access Boundary & Post-Exploitation Verification Table

Target Surface	Principal Tested	Verified Boundary State	Proven Capability	Explicitly Unproven Boundary	Artifact & Full SHA-256
phpMyAdmin Web Interface (/phpMyAdmin/)	Unauthenticated HTTP Client	LOGIN_GATE_ENFORCED (Control Gap: Admin Login Exposed on Network)	HTTP 200 login page reachable over cleartext HTTP	Database administrative login and SQL table access are blocked by authentication gate (not proven)	#2292 (81b234c61b09a750a1dfcb35fdcb4a5f437b062fed4d94f7346016132d43a4c4)

5.2 Stage 9.5 Lateral Movement Validation & Stage 9.6 CIA Impact Assessment

Stage / Dimension	Validation Status	Demonstrated Evidence & Scope Boundary
Stage 9.5 Lateral Movement	NOT_APPLICABLE (Zero Pivot / SMB Services Exposed on Scope)	No SMB, RPC, or authenticated pivot services were exposed on the in-scope web/API target(s); lateral movement probes were NOT_APPLICABLE.
Stage 9.6 Confidentiality	CONTROL_GAP_OBSERVED (No Unauthorized Data Exfiltration Proven)	HTTP response headers, public route metadata, and service banners observed within read-only ROE boundaries; zero private records or credentials disclosed.
Stage 9.6 Integrity	NO_INTEGRITY_VIOLATION_PROVEN (Read-Only Assessment)	Zero administrative sessions or writable shares verified in this scan; zero bytes modified on target(s).
Stage 9.6 Availability	NOT_TESTED (Out of Scope per Non-Destructive ROE)	Zero service disruption; all probes completed within deterministic rate limits.

5B. Exploit Validation Engine (EVE) - Controlled Exploitation Lifecycle & Decisions

TrePath 2.3 Exploit Validation Engine (EVE) bridges vulnerability discovery and remediation by evaluating preconditions, enforcing operator HMAC approval, executing deterministic read-only validation adapters (EVE-AUTH-001, EVE-AUTHZ-001, EVE-INJ-001, EVE-FILE-001, EVE-NET-001), and distinguishing Vulnerability Detected, Exploitability Validated, Impact Verified, and Remediation Verified.

4-Tier Platform Distinction	Canonical Tier Code	Validated Job Count	Evidentiary Standard
1. Vulnerability Detected	VULNERABILITY_DETECTED	17 (13 Obs / 4 Exploit Jobs)	Scanner or passive control observation confirmed in scope; separated from exploitability validation jobs.
2. Exploitability Validated	EXPLOITABILITY_VALIDATED	0	Preconditions satisfied and deterministic test reproduced behavior.

4-Tier Platform Distinction	Canonical Tier Code	Validated Job Count	Evidentiary Standard
3. Impact Verified	**IMPACT_VERIFIED**	0	Controlled test established unauthorized access, privilege escalation, or data exposure.
4. Remediation Verified	REMEDIATION_VERIFIED	0	Subsequent RTEX retest proved the security boundary now holds.
Non-Exploited Breakdown	4-STATE_OUTCOME_MODEL	NA:1 | ROE:3	EXPLOITATION_FAILED: 0 (finding preserved) | EXECUTION_ERROR: 0

5B.1 Executed EVE Validation Jobs & Sealed Evidence Decisions

EVE Job Key	Finding (Asset)	Adapter	Validated Outcome	Platform Tier	Decision	Full EvidenceCore SHA-256
EVE-JOB-00163-S45-F1943	#1943 (ASSET-00084)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	6f2ba4e747bc3638b46a7e87e019cbbc4a1da6f797c3a091553d06920be0aea6
EVE-JOB-00164-S45-F1977	#1977 (ASSET-00086)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	dc0a07bbf026c7b91c13b6382976d4895fe01011eef66511b4009c9bde9ed81c
EVE-JOB-00165-S45-F2024	#2024 (ASSET-00088)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	7fbc50e0abd24d396b3c8621f38637c72aa70374115092a4875070083a341b31
EVE-JOB-00166-S45-F2029	#2029 (ASSET-00089)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	fd39c3306732467100baf0de62b26db9f63791e0c907717d7cc2cc525b69385a
EVE-JOB-00167-S45-F2031	#2031 (ASSET-00090)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	8b0959cf03395df41468a4b943d689c32883ea6e848096a6589a91d6feafaa66
EVE-JOB-00168-S45-F2040	#2040 (ASSET-00092)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	d72af77148b57d235008fa49b18c839270eea87fb6acb4cb33c9c86e24d9ec9f
EVE-JOB-00169-S45-F2042	#2042 (ASSET-00093)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	5f03220d64eb153409a9499d254f8831c3728741a202ebdf4defe011c9f51eb9
EVE-JOB-00170-S45-F2046	#2046 (ASSET-00094)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	f8c60b7a49c571b7f7daefafc9439ccf5c7465fc557de8bdbebb794eb6ec36b6
EVE-JOB-00171-S45-F2052	#2052 (ASSET-00095)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	9156763b358bf1469aeaa360ab33b62add21b0abc68740d00c24550b8df8a74e
EVE-JOB-00172-S45-F2064	#2064 (ASSET-00097)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	036a772b2a130b0b439383926131da66a4e21e2b48df61bd5e988d36f92f61be
EVE-JOB-00173-S45-F1949	#1949 (ASSET-00085)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	3c369c53d5274cb632d2cbb8c2d053df49827ac1ac663b92f6e563d577408ad3
EVE-JOB-00174-S45-F2021	#2021 (ASSET-00087)	EVE-TLS-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	df8bfb8b4db63bbff57b6656fb89075bd155cea55b938dde05657f6ade392d00
EVE-JOB-00175-S45-F2081	#2081 (ASSET-00091)	EVE-CSRF-001	EXPLOITATION_FAILED	VULNERABILITY_DETECTED	REJECTED	c13c1f685a3b47ab06d27b7057d17769a1e6d883b9769b4239adf9ff15f52796
EVE-JOB-00176-S45-F2098	#2098 (ASSET-00087)	EVE-AUTH-001	EXPLOITATION_FAILED	VULNERABILITY_DETECTED	REJECTED	0d6e7fbcb0b8a1487dcff4b4b849cf0ca30bf6bb5bf367f55750587f4edae270
EVE-JOB-00177-S45-F2099	#2099 (ASSET-00092)	EVE-AUTH-001	EXPLOITATION_FAILED	VULNERABILITY_DETECTED	REJECTED	257ae1965135df674f96293f1b792227c9d3abd52da38a8c571e8e5d7106d2f7

EVE Job Key	Finding (Asset)	Adapter	Validated Outcome	Platform Tier	Decision	Full EvidenceCore SHA-256
EVE-JOB-00178-S45-F2090	#2090 (ASSET-00085)	EVE-API-001	OBSERVATION_CONFIRMED	VULNERABILITY_DETECTED	CONFIRMED	073665b9004f825ec5e49aae092c4e542809545245c39e386a1c1f4d2154775e
EVE-JOB-00179-S45-F2097	#2097 (ASSET-00092)	EVE-AUTHZ-001	EXPLOITATION_FAILED	VULNERABILITY_DETECTED	REJECTED	277625832a0f5556db7951d773505d2ec8ffcb4546db75e31afc45517d83a0e1

6. Four-Tier Evidence-Driven Compliance Control Mapping

Primary Finding	PCI-DSS v4.0	NIST SP 800-53 Rev 5	ISO/IEC 27001:2022	CIS Controls v8
HTTP Security Header Policy (CSP/HSTS)	Req 6.4.1 / 6.4.2	SC-8 / SI-10	A.8.26 / A.8.28	Control 16.11
TOMCAT-MGR-001 (Admin Console Auth)	Req 2.2.2 / 8.2.1	IA-5 / AC-6	A.5.17 / A.8.2	Control 4.7 / 5.2
SMB-LIST-001 (Samba Anonymous Enum)	Req 1.3.1 / 2.2.4	AC-3 / SC-7	A.8.20 / A.8.3	Control 3.3 / 4.1
PHPINFO-001 & Legacy Service Hygiene	Req 2.2.6 / 6.3.3	CM-6 / SI-2	A.8.8 / A.8.9	Control 4.1 / 7.1

7. ENUMCORE 6-Stage CVE Applicability Validation & Threat Intelligence

CVE / CWE	Validation State	Preconditions Verified	CVSS	EPSS	CISA KEV	Applicability & Precondition Note
CWE-693	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.

8. Prioritized Remediation Roadmap & 7-Step RTEX Verification Ledger (Stage 8)

Task ID	Origin Host:Port (Asset)	Priority	Status	Work Package Title	Origin-Accurate Fix Guidance	Verification & Closure Rule
REM-00240	owasp.org:443 (ASSET-00084)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_: [owasp.org:443]	Configure the specific missing HTTP response header(s) on origin https://owasp.org:443: Content-Security-Policy: default-src 'self'; fr	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T2_OWASP_ORG_WWW_PROJECT_JUICE_
REM-00241	google-gruyere.appspot.com:443 (ASSET-00086)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM: [google-gruyere.	Configure the specific missing HTTP response header(s) on origin https://google-gruyere.appspot.com:443: Content-Security-Policy: defau	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T15_GOOGLE_GRUYERE_APPSPOT_COM o
REM-00242	pentesterlab.com:443 (ASSET-00088)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM: [pentesterlab.com:443] Mis	Configure the specific missing HTTP response header(s) on origin https://pentesterlab.com:443: Content-Security-Policy: default-src 'se	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T36_PENTESTERLAB_COM on penteste
REM-00243	www.hackthebox.com:443 (ASSET-00089)	P2-Planned	open	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM: [www.hackthebox.com:443] Missing	Configure the specific missing HTTP response header(s) on origin https://www.hackthebox.com:443: X-Frame-Options: DENY (or verify CSP f	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T37_WWW_HACKTHEBOX_COM on www.hackthebox

Task ID	Origin Host:Port (Asset)	Priority	Status	Work Package Title	Origin-Accurate Fix Guidance	Verification & Closure Rule
REM-00244	tryhackme.com:443 (ASSET-00090)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM: [tryhackme.com:443] Missing H	Configure the specific missing HTTP response header(s) on origin https://tryhackme.com:443: Content-Security-Policy: default-src 'self'	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T38_TRYHACKME_COM on tryhackme.c
REM-00245	www.root-me.org:443 (ASSET-00092)	P2-Planned	open	Remediate HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG: [www.root-me.org:443] Missing HTTP	Configure the specific missing HTTP response header(s) on origin https://www.root-me.org:443: X-Frame-Options: DENY (or verify CSP fram	Verification Test: TrePath Retest Adapter for HTTP-HEADER-X_FRAME_OPTIONS::T40_WWW_ROOT_ME_ORG on www.root-me.org:4
REM-00246	www.hackinghub.io:443 (ASSET-00093)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO: [www.hackinghub.io:443] M	Configure the specific missing HTTP response header(s) on origin https://www.hackinghub.io:443: Content-Security-Policy: default-src 's	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T41_WWW_HACKINGHUB_IO on www.hac
REM-00247	pentest-ground.com:443 (ASSET-00094)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM: [pentest-ground.com:443]	Configure the specific missing HTTP response header(s) on origin https://pentest-ground.com:443: Content-Security-Policy: default-src '	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T42_PENTEST_GROUND_COM on pentes
REM-00248	genai.owasp.org:443 (ASSET-00095)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG: [genai.owasp.org:443] Missi	Configure the specific missing HTTP response header(s) on origin https://genai.owasp.org:443: Content-Security-Policy: default-src 'sel	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T43_GENAI_OWASP_ORG on genai.owa
REM-00249	vwad.owasp.org:443 (ASSET-00097)	P2-Planned	open	Remediate HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG: [vwad.owasp.org:443] Missing	Configure the specific missing HTTP response header(s) on origin https://vwad.owasp.org:443: Content-Security-Policy: default-src 'self	Verification Test: TrePath Retest Adapter for HTTP-HEADER-CONTENT_SECURITY_POLICY::T46_VWAD_OWASP_ORG on vwad.owasp
REM-00250	github.com:443 (ASSET-00085)	P3-Backlog	open	Remediate HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA: [github.com:443] Missin	Configure the specific missing HTTP response header(s) on origin https://github.com:443: Permissions-Policy: geolocation=(), microphone	Verification Test: TrePath Retest Adapter for HTTP-HEADER-PERMISSIONS_POLICY::T3_GITHUB_COM_DIGININJA_DVWA on githu
REM-00251	portswigger.net:443 (ASSET-00087)	P3-Backlog	open	Remediate HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY: [portswigger.net:443]	Configure the specific missing HTTP response header(s) on origin https://portswigger.net:443: Referrer-Policy: strict-origin-when-cross	Verification Test: TrePath Retest Adapter for HTTP-HEADER-REFERRER_POLICY::T35_PORTSWIGGER_NET_WEB_SECURITY on port
REM-00252	www.hackthissite.org:443 (ASSET-00091)	P3-Backlog	open	Remediate ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG: [www.hackthissite.org] [WebPulse] HTML	Include a cryptographically random anti-CSRF token in state-changing POST forms and enforce SameSite=Strict/Lax cookies. [Affected Asse	Verification Test: TrePath Retest Adapter for ENUM-FORM-NOCSRF-1::T39_WWW_HACKTHISSITE_ORG on www.hackthissite.org:
REM-00253	portswigger.net:443 (ASSET-00087)	P3-Backlog	open	Remediate DAST-ADMIN-ACCESS-EP-02700: [ADMIN-ACCESS-001] Candidate Route or Login Interface Dis	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS	Verification Test: TrePath Retest Adapter for DAST-ADMIN-ACCESS-EP-02700 on portswigger.net:443 (ASSET-00087) | Clo

Task ID	Origin Host:Port (Asset)	Priority	Status	Work Package Title	Origin-Accurate Fix Guidance	Verification & Closure Rule
REM-00254	www.root-me.org:443 (ASSET-00092)	P3-Backlog	open	Remediate DAST-ADMIN-ACCESS-EP-02832: [ADMIN-ACCESS-001] Candidate Route or Login Interface Dis	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS	Verification Test: TrePath Retest Adapter for DAST-ADMIN-ACCESS-EP-02832 on www.root-me.org:443 (ASSET-00092) | Clo
REM-00255	github.com:443 (ASSET-00085)	P3-Backlog	open	Remediate API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI: [github.com:443] API Rate-	Emit standardized RFC-draft RateLimit-* response headers on API endpoints and verify edge/gateway throttling thresholds. [Affected Asse	Verification Test: TrePath Retest Adapter for API-RATE-LIMIT-HEADERS-MISSING::T5_GITHUB_COM_OWASP_CRAPI on github.c
REM-00256	www.root-me.org:443 (ASSET-00092)	P3-Backlog	open	Remediate DAST-API-AUTHZ-EP-02827: [API-AUTHZ-001] Anti-Bot / Honeypot Challenge API Route Obse	No remediation required for intentional anti-bot/honeypot challenge endpoints; verify WAF/bot-protection rules. [Affected Asset: www.ro	Verification Test: TrePath Retest Adapter for DAST-API-AUTHZ-EP-02827 on www.root-me.org:443 (ASSET-00092) | Closur

8.1A Seven-Step Remediation & Retest Verification Loop (RTEX Lifecycle)

Step	RTEX Lifecycle Stage	Current Status	Verification & EvidenceCore Protocol
Step 1	Baseline Finding Sealed (T0)	COMPLETED	17 consolidated findings sealed with 9-field provenance & 64-hex SHA-256.
Step 2	Remediation Assigned (REM-xxxxx)	COMPLETED	17 origin-bound RemediationTask work packages generated.
Step 3	Deterministic Retest Executed	STANDBY_AWAITING_FIX	0 live retest execution(s) recorded via POST /api/v1/findings/{id}/retest/execute.
Step 4	Negative-Control Validation	READY	Verifies response is not a generic WAF block, anti-bot challenge, or out-of-scope redirect.
Step 5	EvidenceCore Retest Sealing	READY	Before/after HTTP or TCP transcript sealed with fresh FIPS 180-4 SHA-256 digest.
Step 6	Closure Decision (REMEDIATION_VERIFIED)	PENDING_CLOSURE	Promotes Finding to REMEDIATION_VERIFIED only when deterministic control check passes.
Step 7	T1 Post-Retest Risk Recalculation	HYPOTHETICAL_FORECAST_ONLY	Recalculates live T1 risk index; until retest executes, 2.1/10 remains labeled HYPOTHETICAL_PROJECTION.

8.2 Deterministic Retest Execution Ledger (RTEX-xxxxx)

Retest Key	Target Finding	Execution Status	Resulting Proof State	Evidence Artifact	Verification Notes
RTEX-STANDBY	All Open Findings	AWAITING_PATCH	PENDING_RETEST	EvidenceCore Ready	Use POST /api/v1/findings/{id}/retest/execute after applying remediation to record cryptographic closure proof.

9. EvidenceCore Cryptographic Integrity, RFC 8032 Ed25519 Signature Bundle & Quality Gates

9.0 Verifiable RFC 8032 Ed25519 Signature, UTC Timestamp Reconciliation & Key Discovery

Signing Algorithm & Authority	Ed25519 (RFC 8032) + SHA-256 (FIPS 180-4) | Signer: TrePath-EvidenceCore-Authority-v2.6
Reconciled UTC Timestamps	Scan Started: 2026-11-02T16:22:07Z | Scan Completed: 2026-11-02T16:23:50Z | Report Generated & Signed: 2026-11-02T17:58:03Z (Drift: 0s)
Trusted Public-Key Discovery	Well-Known URI: /.well-known/trepath-evidencecore-pubkey.json | Verify Endpoint: /api/v1/unified/verify-signature
Canonical Manifest SHA-256	4556059d8b0726992141766d2cd9871be4292458d8a3b8c170b9798a6fdf4f0a
Ed25519 Signature (128-Hex)	24df5e7668fb3eb21a931ff66690a4c18f85ce710c3e3f09e220d5166885333f54b8545f8cd9587284a6d91df363f2d3a99b4ad6ac81d2d2aaf9aca059c4ac0f

Ed25519 Signature (Base64)	JN9edmj7PrIakx/2ZpCkwY+FznEMPj8J4iDVFmiFMz9UuFRfjNlYcoSm2R3zY/LTqZtK1qyB0tKq+aygWcSsDw==
Public Key Fingerprint SHA-256	bc91f1e0b7c69696547e1efa0f05a7f9c1a201abf0cf80dabf698e43624c7eb1
Public Key (Raw Hex / PEM)	Hex: 61e14ce688b5c816bcc76b30bcc93c9c2914fa085a2ff326594cd1c5565f05b9 | PEM: -----BEGIN PUBLIC KEY----- MCowBQYDK2VwAyEAYeFM5oi1yBa8x2swvMk8nCkU+ghaL/MmWUzRxVZfBbk= -----END PUBLIC KEY-----
Signature Verification Result	VERIFIED_AUTHENTIC (Bound Artifacts: 196)
Live Tamper-Detection Self-Test	PASSED (Tampered Manifest Deterministically Rejected) - 1-bit payload mutation + 1-byte signature mutation deterministically rejected by Ed25519 verifier.

9.1 Automated Acceptance & Negative Quality Gates (AT-01..AT-10 + NG-01..NG-06)

Gate ID	Verification Domain	Dynamic Acceptance & Negative Quality Gate Rule	Status
AT-01/02	Scope & Redirect Provenance	7-stage scope funnel reconciled (46 requested -> 14 origin assets); external links isolated.	**PASSED**
AT-03..06	Proof-State Reconciliation	**Executive, Section 1.2 & Stage 9 agree: CONFIRMED_ADMIN_AUTH=0, IMPACT_VERIFIED=0.**	**PASSED**
AT-07/08	Risk & Port Reconciliation	4-State port discovery reconciled (0 TCP ports, 368 HTTP endpoints); 7 risk dimensions sum (39.4/100) matches headline (39.4/100).	**PASSED**
AT-09/10	Origin Consolidation & Ed25519	179 raw observations -> 17 unique findings; Consistency=100.0%, Ed25519=VERIFIED_AUTHENTIC.	**PASSED**
NG-01	No Admin Exposure Claim from Route Rea	Candidate /dashboard or /admin HTTP 200 routes without verified admin console controls classified as OBSERVATION_CONFIRMED :: LOGIN_INTERFACE_OR_ROUTE_DISCOVERED (Low).	**PASSED**
NG-02	No Outdated Software Claim for Current	Modern versions (e.g. nginx 1.31.8) marked is_outdated=False; banner-only fingerprints use OBSERVATION_CONFIRMED :: VERSION_FINGERPRINT_BANNER_ONLY.	**PASSED**
NG-03	No API Vulnerability Claim from Anti-B	Anubis / /.within.website/ honeypot and public API routes classified as OBSERVATION_CONFIRMED :: ANTIBOT_OR_PUBLIC_API_ROUTE_OBSERVED (Low).	**PASSED**
NG-04	No Rate-Limit Absence Claim from Missi	Absent X-RateLimit-* headers classified as OBSERVATION_CONFIRMED :: RATE_LIMIT_HEADER_ABSENT_ENFORCEMENT_UNTESTED (Low).	**PASSED**
NG-05	Zero Cross-Asset Contamination in Reme	All 17 RemediationTask rows bound to exact finding asset_id and effective_origin host:port.	**PASSED**
NG-06	No Unverified Post-Remediation Risk Cl	Executed retests = 0; post-hardening 2.1/10 explicitly labeled HYPOTHETICAL_PROJECTION.	**PASSED**

10. Unified Security Platform Integration (XTRIKE SAST + TrePath 2.6 Autonomous Attack-Path Valida

10.0 Unified Finding Registry (Code Source-to-Sink vs. External Black-Box Provenance Separation)

Unified ID	Finding (Asset)	Source Code vs. Black-Box Rule Provenance	Expedite Strike / EVE State	4-Track Score Summary	Noctis Posture State
UFR-045-001	F-01 (ASSET-00084)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-002	F-02 (ASSET-00086)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-003	F-03 (ASSET-00088)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH

Unified ID	Finding (Asset)	Source Code vs. Black-Box Rule Provenance	Expedite Strike / EVE State	4-Track Score Summary	Noctis Posture State
UFR-045-004	F-04 (ASSET-00089)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-005	F-05 (ASSET-00090)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-006	F-06 (ASSET-00092)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-007	F-07 (ASSET-00093)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-008	F-08 (ASSET-00094)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-009	F-09 (ASSET-00095)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-010	F-10 (ASSET-00097)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:4.3 | Ctrl:46.0	ACTIVE_TELEMETRY_WATCH
UFR-045-011	F-11 (ASSET-00087)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:3.2 | Ctrl:34.0	ACTIVE_TELEMETRY_WATCH
UFR-045-012	F-12 (ASSET-00085)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	CONTROL_GAP_CONFIRMED	CVSS:3.1 | Ctrl:31.0	ACTIVE_TELEMETRY_WATCH
UFR-045-013	F-13 (ASSET-00091)	External Black-Box (Rule: trepath/dast_sensor_rule:ENUM-FORM-NOCSRF-2::T39_WWW_HACKTHISSITE_ORG)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH
UFR-045-014	F-14 (ASSET-00087)	External Black-Box (Rule: trepath/dast_sensor_rule:DAST-ADMIN-ACCESS-EP-02700)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH
UFR-045-015	F-15 (ASSET-00092)	External Black-Box (Rule: trepath/dast_sensor_rule:DAST-ADMIN-ACCESS-EP-02832)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH
UFR-045-016	F-16 (ASSET-00085)	External Black-Box (Rule: trepath/finding_normalizer .py:HeaderPolicyEvaluator-2.6)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH
UFR-045-017	F-17 (ASSET-00092)	External Black-Box (Rule: trepath/dast_sensor_rule:DAST-API-AUTHZ-EP-02827)	OBSERVATION_CONFIRMED	CVSS:N/A (Observation) | Ctrl:0.0	ACTIVE_TELEMETRY_WATCH

10.1 Autonomous 9-Stage Orchestration Architecture & Centralized Version Manifest

Stage	Engine Module (Version)	Execution Outcome
Stage 1-2	Scope & WebPulse 2.6 + TargetIntel 2.6	Verified 14 in-scope asset(s) (owasp.org (+13 authorized origins across 14 in-scope assets)), 0 open TCP ports, and 368 HTTP endpoints.

Stage	Engine Module (Version)	Execution Outcome
Stage 3	ENUMCORE 2.6	Mapped CPEs and separated precondition-verified KEVs from banner-only candidates.
Stage 4-5	HeaderPolicyEvaluator 2.6 (Context & CSP Report-Only) & EVE 2.6	Enforced RoE scope lock & read-only HTTP DAST checks (0 destructive or out-of-scope PoCs executed).
Stage 6-7	Expedite Strike 2.6 & AttackGraph 2.6 (Causal Edge & Continuous Diff)	Assigned 4-level admin boundary taxonomy and built per-edge evidence-backed attack chains.
Stage 8-9	RiskEngine 2.6, RTEX 2.6 & Noctis 2.6	Computed 7-dimension risk (T0=3.9/10, T1=3.9/10) and signed RFC 8032 Ed25519 manifest.

11. Sign-Off & Deliverables Attestation (TrePath 2.6 Autonomous Attack-Path Validation, Target Intelli

Role	Attestation Statement	Signature / Timestamp
Lead Penetration Tester	All findings, origins, and PoC transcripts verified against EvidenceCore SHA-256 & Ed25519 seals.	SIGNED | 2026-11-02 17:58:03 UTC
Principal Security Architect	TrePath 2.6 Autonomous Attack-Path Validation, Target Intelligence & RTEX Assurance Engine (TP26-BUILD-20261102-AUTONOMOUS-ASSURANCE) AT-01..AT-10, NG-01..NG-06 & 26/26 Quality Gates passed.	VERIFIED | 2026-11-02 17:58:03 UTC
Client System Owner	Acknowledges receipt of prioritized remediation roadmap and RTEX retest workflow.	_____